

IoT Security Incident Response Assessment

Unknown Smart-Home Device Repeatedly Connecting to an MQTT Broker

Part 2 (35 Marks): Incident Response, Security Monitoring and Mitigation

Name	Jai Kosick
Registration No.	192421367
Subject	DevSecOps Engineering and Application Security
Subject Code	CSA5802

1. Scenario Overview and Alert Analysis

The Security Operations Centre (SOC) receives repeated IDS/SIEM alerts indicating that a device not present in the organisation's asset inventory is repeatedly opening TCP sessions to the smart-home MQTT broker on ports 1883/8883. The connections are frequent, occur at irregular intervals inconsistent with normal telemetry patterns, and in several instances the device attempts to subscribe to broad topic wildcards. Because MQTT is the control-plane protocol for actuators such as door locks, cameras and thermostats, an unauthenticated or under-authorised client on this broker represents a direct risk to physical safety and privacy, not merely to data confidentiality.

1.1 Indicators of Compromise (IoC) Identified

Indicator	Observation	Significance
Unknown MAC / OUI	Device MAC address and vendor OUI do not match any entry in the asset/device inventory or DHCP reservation list.	Rogue or spoofed device; not provisioned through the normal onboarding process.
Repeated connect/disconnect	High-frequency CONNECT packets to the broker, several within seconds, some followed by immediate disconnects.	Typical of credential brute-forcing, session scanning, or a misconfigured/compromised bot client.
Anonymous or default credentials	Broker logs show authentication with blank, default, or previously leaked device credentials.	Confirms the broker permits weak or anonymous authentication.
Wildcard topic subscription	Client subscribes to home/# or +/status rather than a single expected telemetry topic.	Reconnaissance behaviour: enumerating all rooms/devices, harvesting sensitive state (locks, cameras).
Plaintext channel	A share of the sessions use port 1883 without TLS.	Credentials and payloads are sniffable on the local network segment.
Unexpected publish to control topics	Attempted publish to */lock/command or */camera/config topics.	Possible attempt at unauthorised actuation of physical devices.

1.2 Incident Classification

Using a NIST/SANS-style category scheme, this event is classified as **Unauthorised Access via a Rogue IoT Device**, with a secondary characteristic of reconnaissance/enumeration against the message broker. Given that MQTT brokers in smart-home deployments typically bridge to actuation topics, the potential impact is rated **High** (safety and privacy impact if command topics are reached) while current likelihood of full compromise is assessed as **Medium**, since no confirmed successful command injection has yet been observed in the logs. This yields an overall incident severity of **High-Priority / Sev-2**, warranting immediate SOC response rather than routine ticketing.

2. Incident Response Plan

The response follows the NIST SP 800-61r2 incident-handling lifecycle, adapted for constrained IoT/MQTT environments where devices cannot always run full endpoint agents.

2.1 Preparation

- Maintain an accurate, automatically-reconciled IoT asset inventory (MAC, certificate serial, firmware version, owner).

-
- Pre-stage an incident response runbook specific to MQTT/broker abuse, with defined roles (SOC analyst, network engineer, IoT platform owner).
 - Ensure the broker is configured to log CONNECT/DISCONNECT, AUTH failures, and ACL denials to a central SIEM.
 - Pre-provision an isolated quarantine VLAN and a broker "honey-topic" for triage without touching production topics.

2.2 Detection and Analysis

- Correlate SIEM alerts (broker logs, NetFlow/DPI, DHCP/ARP tables) to confirm the device is genuinely unrecognised, not a mis-tagged asset.
- Capture packet traces (where port 1883 is plaintext) to inspect CONNECT client-id, username, and subscribed topic filters.
- Check certificate store / broker ACL logs to confirm whether the client presented a valid client certificate — absence confirms rogue status.
- Determine blast radius: which topics were subscribed/published to, and whether any actuator command topics were touched.

2.3 Containment

- **Short-term:** Immediately revoke/disable the offending client's broker credentials and, if used, its TLS certificate (add to the Certificate Revocation List / OCSP responder).
- **Short-term:** Apply a firewall/NAC rule to move the device's switch port or Wi-Fi association into a quarantine VLAN with no route to the broker or to other IoT devices.
- **Long-term:** Tighten broker ACLs so that even if credentials are reused elsewhere, no client can reach control topics without an explicit allow rule.
- **Long-term:** Disable anonymous/blank-credential authentication on the broker and enforce mutual TLS for all clients while containment is in effect.

2.4 Eradication

- Physically or logically remove the rogue device from the network if it cannot be identified as a legitimate asset.
- Rotate all broker credentials and re-issue client certificates for legitimate devices in case of shared/leaked default credentials.
- Patch or reset firmware on any legitimate device found to be misconfigured (e.g., shipped with anonymous access enabled).
- Review and correct the broker configuration file (mosquitto.conf or equivalent) to remove the root cause: anonymous access, overly-permissive default ACL, or missing TLS.

2.5 Recovery

- Re-enable normal operation of legitimate devices only after they re-authenticate using new certificates and pass ACL validation.
 - Monitor the broker and network at heightened sensitivity (lower alert thresholds) for 72 hours post-incident.
 - Validate that no unauthorised state changes (e.g., lock/unlock events, camera reconfiguration) occurred during the exposure window, using device audit logs.
-

2.6 Post-Incident Activity (Lessons Learned)

- Conduct a blameless post-incident review; document root cause, timeline, and response effectiveness.
- Update the asset inventory/onboarding process so every new device must be provisioned with a signed certificate before broker access is granted.
- Feed the observed IoCs (client-id patterns, topic wildcards) back into SIEM detection rules and the broker's rate-limiting configuration.
- Update this runbook and schedule a tabletop exercise to validate the improved controls.

3. Security Monitoring Recommendations

- **Centralised broker logging:** Forward Mosquitto/EMQX/HiveMQ connect, disconnect, auth-failure and ACL-deny events to a SIEM (e.g., Splunk, ELK) for correlation and long-term retention.
- **Behavioural baselining:** Establish a normal-traffic profile per device (publish rate, topic set, payload size) and alert on deviation — this is what first surfaced the rogue device.
- **Deep packet inspection (DPI) for MQTT:** Use an IDS with an MQTT protocol parser to flag anomalous CONNECT flags, oversized client IDs, or wildcard subscriptions in real time.
- **Network flow monitoring / NAC:** Continuously reconcile connected MAC/IP pairs against the asset inventory; auto-quarantine unknown devices via 802.1X.
- **Broker-side rate limiting and connection throttling:** Cap CONNECT attempts per source IP/client-id per minute to blunt brute-force or scanning behaviour.
- **Deception:** Maintain a decoy/honey-topic that no legitimate device should ever touch; any publish/subscribe to it is a high-confidence malicious signal.
- **Certificate lifecycle monitoring:** Alert on certificates nearing expiry, on CRL/OCSP check failures, and on any client presenting a revoked certificate.

4. Mitigation Strategies

Layer	Control	Purpose
Identity	Mutual TLS with X.509 client certificates issued per device via an internal PKI/IoT CA.	Strong, unspoofable device identity; replaces weak shared passwords.
Network	VLAN/microsegmentation isolating IoT devices from each other and from core infrastructure; NAC-driven quarantine for unknown MACs.	Limits lateral movement and blast radius of any single compromised device.
Authorisation	Topic-level broker ACLs enforcing least privilege (publish-only to own telemetry topic; no access to command topics).	Prevents privilege escalation and unauthorised actuation even by an authenticated client.
Transport	Enforce TLS 1.2+ on port 8883 only; disable plaintext 1883 and anonymous access.	Protects credentials and payloads from network sniffing.
Lifecycle	Automated onboarding/offboarding, credential rotation, and certificate revocation (CRL/OCSP).	Ensures decommissioned or compromised devices lose access immediately.
Monitoring	SIEM correlation, anomaly detection, rate limiting, honey-topics (see Section 3).	Enables early detection of the next rogue-device attempt.
Governance	Regular firmware patching, vendor security review before onboarding, periodic penetration testing of the IoT estate.	Reduces the attack surface introduced by insecure-by-default devices.

5. Justification of Certificate Authentication, Device Isolation and Broker ACLs

The three controls specified for this assessment map directly onto the classic Authentication, Authorisation and Containment triad, and each one closes a specific gap that allowed this incident to occur.

5.1 Certificate-Based Authentication (Mutual TLS)

MQTT's default authentication (username/password, or none at all) is precisely what allowed an unknown device to connect in this incident: credentials are frequently shared, hard-coded in firmware, or guessable, and travel in the clear on port 1883. Replacing this with **mutual TLS using X.509 client certificates** issued by an internal Certificate Authority provides:

- **Strong, cryptographic device identity** that cannot practically be guessed or brute-forced, unlike shared passwords.
- **Mutual verification:** the broker authenticates the device's certificate and the device authenticates the broker's certificate, which prevents both rogue-client connections and man-in-the-middle/rogue-broker attacks.
- **Per-device revocation** via CRL/OCSP — a single compromised or decommissioned device can be cut off instantly without resetting a shared secret used by every other device.
- **Direct remediation of the observed incident:** under mTLS, the unknown device would never complete the TLS handshake, so it would be rejected before it could even attempt a CONNECT packet, eliminating the alert at its source.

5.2 Device Isolation (Network Segmentation / Microsegmentation)

Authentication alone does not stop a device that manages to obtain valid-looking credentials, nor does it limit what a device can reach once on the network. **Isolating IoT devices onto a dedicated VLAN or micro-segment**, separate from the broker's management interface, user endpoints, and other IoT devices, is justified because:

- It **contains the blast radius** — even if one smart-home device is compromised, it cannot pivot laterally to attack the broker's administrative port, cameras, or other devices on a flat network.
- It enables **automatic quarantine:** a NAC/802.1X system can immediately drop an unrecognised MAC address (exactly the device in this alert) into an isolated VLAN with no route to the broker, containing the incident within seconds rather than waiting for manual analyst action.
- It supports **Zero Trust principles** (NIST SP 800-207) — network location is never implicitly trusted; every flow between segments must be explicitly permitted by firewall policy.
- It reduces the value of stealing one device's credentials, since network position alone does not grant reachability to sensitive segments.

5.3 Broker Access Control Lists (Topic-Level Authorisation)

Even a fully authenticated, correctly segmented device should not have unrestricted publish/subscribe rights across the entire topic tree. **Broker ACLs enforcing least privilege at the topic level** are justified because:

- They stop the specific behaviour seen in the alert — a client subscribing to `home/#` — by restricting each device to only its own telemetry topic (e.g., `home/livingroom/sensor1/temperature`) and denying wildcard subscriptions.
-

- They prevent **unauthorised command injection**: a sensor device with a legitimate certificate still cannot publish to home/frontdoor/lock/command unless explicitly authorised, which stops a compromised-but-authenticated device from actuating physical controls.
- They provide **defence in depth** — if authentication is ever bypassed or a certificate is cloned, ACL denial is a second independent control and its logs (ACL-deny events) become a high-fidelity detection signal in their own right.
- They support the **principle of least privilege and separation of duties** between telemetry-publishing devices and command-and-control topics used by hubs/automations.

5.4 Why the Three Controls Are Complementary

Each control answers a different security question, and together they form layered defence rather than redundant protection:

Control	Question it answers	Failure it prevents
Certificate Authentication	"Who are you?"	An unknown/rogue device connecting at all.
Device Isolation	"Where can you reach?"	Lateral movement to the broker's admin plane or other devices.
Broker ACLs	"What are you allowed to do?"	Privilege escalation, topic hijacking, or unauthorised actuator commands.

Applied together, these controls would have prevented the incident at three independent points: the unknown device would have failed the TLS handshake (authentication), would have had no network path to the broker even if it somehow obtained credentials (isolation), and would have been denied at the topic level even if it reached the broker with valid credentials (authorisation) — which is the layered assurance a single control alone cannot provide.

6. Conclusion

The repeated, unauthenticated connections from an unrecognised device to the smart-home MQTT broker represent a credible IoT security incident with potential safety and privacy impact. A structured NIST-aligned incident response process — preparation, detection, containment, eradication, recovery and lessons learned — enables the SOC to move quickly from alert to containment. Long-term resilience, however, depends on closing the underlying architectural gaps: certificate-based mutual TLS to establish strong device identity, network isolation to contain any device that is nonetheless compromised, and broker ACLs to enforce least privilege on what each device may publish or subscribe to. Together these three controls implement authentication, containment and authorisation as complementary, defence-in-depth layers appropriate for constrained IoT/MQTT environments.

References

- *NIST SP 800-61 Rev. 2, Computer Security Incident Handling Guide, National Institute of Standards and Technology.*
- *NIST SP 800-207, Zero Trust Architecture, National Institute of Standards and Technology.*
- *OWASP Internet of Things (IoT) Top 10 Project, OWASP Foundation.*
- *OASIS MQTT Version 5.0 Specification — Security Considerations, OASIS Standard.*